ZenHR — Functional & Role-Based Requirements Specification

SaaS Human Resource Management System · Version 2.1 (Consolidated + supervisor additions)

Merges the original project brief, the functional requirements v1.1/v1.2, the requirements changelog, the module-access-by-role guide, the probation-scope update and the supervisor's additions list into one document. October 2026.

> **Revision note (v2.0):** This version is the single source of truth. Where the earlier documents disagreed, the later one won (probation update → functional requirements → changelog → role guide → original brief). Four points are fixed by the company owner and are not open questions: (1) leave is gated by a 3-month probation for the Employee role only; (2) remote work is a standing two-step permission (manager, then HR); (3) GPS/location verification is removed on privacy grounds and replaced by optional, consent-based location capture; (4) a company that does not pay for 2 consecutive months is locked out until payment resumes.

> **Update (v2.1, 25 October 2026):** The supervisor's additions list is now merged in: work timer with break notifications, login IP tracking, Stripe payment collection with scheduled retries, Basic and Premium tiers, a revised leave flow (Team Lead, then HR final approval; types Casual, Sick, Annual), Cloudinary or S3 file storage, a restricted Gemini assistant, employee status badges, and deployment to Vercel and Render by **10 November 2026**. Where this conflicts with v2.0 (leave approval, plan tiers, AI access), the supervisor's list wins and the point is marked for confirmation in Section 22. Items the supervisor excluded are listed in Section 20.

---

1. Purpose

The original brief defines the technology stack, module list and development phases at a high level. This document defines exactly **what each user role can see and do**, together with the workflows, approvals and data-ownership rules that were previously ambiguous. It serves two purposes:

1. A build specification the code can be checked against.

2. A defensible functional design for the Final Year Project viva and report.

It extends, and does not replace, the SRS and SDD in `docs/`.

2. Product Overview

ZenHR is a multi-tenant SaaS HRMS: one platform serves many companies, each with its own isolated data, its own subscription plan, and its own users. It must be scalable, secure and production-ready.

Each company (tenant) owns: company profile, departments, designations, employees, attendance, leave, payroll, AI usage, subscription and storage. **No company can ever access another company's data.**

2.1 Technology stack

Layer	Technology
Frontend	Next.js (App Router), React, TypeScript (strict), Tailwind CSS, ShadCN UI, TanStack Query, React Hook Form, Zod, Recharts
Backend	Node.js, NestJS, PostgreSQL, Prisma ORM, JWT + refresh tokens, Socket.IO, Nodemailer, BullMQ + Redis, Multer + Cloudinary or AWS S3
Payments	Stripe subscriptions with the prebuilt payment widget and scheduled retries
AI	Google Gemini API with prompt engineering, guardrails, context injection, prompt templates and conversation history
Infrastructure	Docker, Nginx, GitHub Actions CI/CD, Render (backend), Vercel (frontend)

Google OAuth login was in the original brief; see Section 22 (open items) for its current status.

3. User Hierarchy

```
PLATFORM LEVEL
Super Admin (platform owner — all companies)
 │
 ├── Operation Manager (platform support role, reports to Super Admin)
 │
COMPANY LEVEL (one set per tenant)
 ▼
Company Admin (CEO / Owner — owns one company)
 ▼
HR Manager (runs HR operations for the whole company)
 ▼
Department Manager (owns one department)
 ▼
Team Lead (owns one team inside a department)
 ▼
Employee (owns only their own records)
```

There are **seven roles** (two platform, five company). Authority narrows at every level down the chain.

Two rules decide what a user can touch, and both must be enforced:

1. **Role** decides which modules and actions are available (sidebar and permission guards).
2. **Data scope** decides which records inside an allowed module are visible: own company, own department, own team, or own records only. Two Department Managers have the same role but must never see each other's departments. Data scope is enforced in the services, not just the sidebar.

Approvals for attendance and leave flow upward through the reporting line. HR is the single authority for attendance exceptions and final remote-work approval; Department Managers and Team Leads own the data of their own people.

4. Module List

Every logged-in user lands on the same shell with role-filtered content.

#	Module	Purpose
1	Dashboard	Role-specific KPIs and summary

#	Module	Purpose
2	Companies	Platform-only: list, add, suspend/reactivate companies
3	Employees	Directory and records (scope varies by role)
4	Departments	Department list and structure
5	Designations	Job titles
6	Attendance	Check-in/out, remote work, approvals, reports, calendar
7	Leave	Apply, approve, balances, history
8	Payroll	Salary structure, payslips, history, bulk generation
9	Resource Requests	Request company resources through an approval chain
10	Approvals	Inbox of requests awaiting the current user
11	AI Assistant	HR chatbot scoped to company and role
12	Analytics	Charts by role scope
13	Billing	Subscription and plan management
14	Notifications	Real-time and email alerts
15	Settings	Profile, preferences, company and platform settings

5. Role-by-Role Functional Requirements

5.1 Super Admin (platform level)

The Super Admin belongs to no company and operates at platform level. Company modules (Employees, Attendance, Leave, Payroll) do not appear in the sidebar.

Can do

- View every company registered on the platform, with plan, subscription start and expiry dates, and payment/billing status.
- Add a company (manual onboarding), set its initial plan, and suspend or reactivate it.

- View platform analytics: total companies, revenue, subscriptions, active users, AI usage, server/system health.
- View all companies' subscriptions and invoices; configure plans, pricing and platform-wide AI limits.
- Receive in-app and email notices before any company's subscription expires (configurable lead time, default 7 days).
- See a company flagged **Suspended (Non-Payment)** with its payment history.

Cannot do

- See inside a company's operational data (individual attendance, payroll amounts, employee records). The only exception is an explicit **support/impersonation mode**, which must require a stated reason, be time-limited, and be written to the audit log.

5.2 Operation Manager (platform support role)

A trimmed-down platform role that reports to the Super Admin, so routine support does not need the Super Admin each time. Scope is intentionally limited; more platform roles may be added later, so the permission system must allow this without restructuring.

Can do (read-only / support)

- View the platform dashboard and analytics.
- View the company list and each company's subscription status.
- Support tasks delegated by the Super Admin (monitoring, onboarding assistance).
- Edit their own profile.

Cannot do

- Add, edit, suspend or delete companies; manage billing or plans; see AI settings; see any company's operational data.
- Every action taken must be audit-logged because the role operates at platform level.

5.3 Company Admin (CEO / Owner)

Owns one company with full visibility inside it. Views rather than actions day-to-day HR tasks unless the person also holds the HR role.

Can do

- View all employees with role, current login status, last login time and last login device/approximate location (see Section 14.3).

- View company-wide payroll, payslips, leave, attendance, departments, designations, AI usage and analytics.
- View the presence graph: employees present, absent and on leave today, with trend over time.
- Manage company structure: departments (full CRUD, assign managers), designations, company profile and settings (logo, office details, probation length, approval chains).
- Manage the company's subscription: view plan, start and expiry dates, upgrade or downgrade, view invoices.
- Configure company AI settings and use the assistant; receive work-timer break notifications; record CEO-level leave together with HR.
- Act as an approver only at the top of a chain: HR Manager's leave and remote-work requests, and as fallback for a Department Manager's requests; revoke an active remote-work permission.

Cannot do

- See any other company's data.
- Approve routine attendance exceptions or ordinary leave (HR and managers own those).

5.4 HR Manager

The operational engine of the company. Acts like an employee for their own records and manages everyone's HR data.

Own records: checks in and out, applies for leave, views own payslips and attendance history.

Company-wide responsibilities

- Full access to every employee record: create and edit employees, documents, promotions, resignations, bulk import.
- Manage departments and designations, leave types, shift schedules and company policies.
- Payroll: manage salary structures, run payroll, generate payslips (single and bulk), salary revisions, bank details.
- **Remote work: final (second) approval** after the requester's manager has approved.

- **Attendance exceptions:** review the queue of unauthorized remote check-ins and other flagged anomalies; mark an employee Absent if they neither checked in nor have approved leave.
- Give final approval on leave requests (after the Team Lead), see the company-wide leave list and calendar, and open each request to read the reason and download the prescription.
- Configure the AI assistant, company policies, approval chains, the leave reason/prescription setting and the IP whitelist for remote and hybrid staff; view company analytics and AI logs.

Cannot do

- Access billing or subscription management (Company Admin only), or see other companies.

5.5 Department Manager

Owns one department. Both a worker and a first-level approver.

Can do

- Check in and out (Onsite by default; Remote only with an approved Remote Work permission).
- View and manage their own department: Team Leads and Employees, attendance, leave requests, department analytics.
- Approve leave submitted by their direct reports (Team Leads, and employees reporting to them directly); HR gives the final approval.
- Give the first approval on Remote Work and Resource requests from their department.
- View their own payslip and a limited, view-only summary of team payroll.
- Use the AI assistant.

Cannot do

- See or manage other departments, or approve their own leave or remote work (those go to HR, with Company Admin as fallback).

5.6 Team Lead

Owns one team inside a department. Same shape as the Department Manager, narrower scope.

Can do

- Check in and out (Remote only with approved permission).
- View and manage their own team: employees, team attendance, leave status, basic records, team analytics.
- Give the **first approval on leave** requests from team members (HR gives the final approval), and first approval on Remote Work and Resource requests.
- View their own payslip only (team payroll is hidden).
- Use the AI assistant.

Cannot do

- Approve their own requests (they go to the Department Manager), or see other teams or departments.

5.7 Employee

The narrowest role: everything is "self".

Can do

- Check in and out. Onsite is automatically Present; Remote works only on dates covered by an approved permission.
- View own attendance history and calendar, payslips, salary history, leave balance and history.
- Apply for leave (Casual, Sick with prescription, Annual) once past probation.
- Submit Remote Work requests and Resource requests; submit a resignation.
- Manage own profile, documents, emergency contacts, education, experience and skills.
- Optionally consent, in Settings, to location capture at check-in (never required, withdrawable at any time).
- Use the AI assistant for HR questions scoped to their own context.

Cannot do

- View any other employee's data, or approve anything.

---

6. Attendance & Remote Work

> **Location tracking removed.** Mandatory GPS verification was dropped on the company owner's instruction as a privacy concern. Location is captured only if the employee has explicitly consented, and then only as informational metadata. It never blocks, approves or rejects a check-in. Face verification is out of scope.

6.1 Check-in and check-out

1. The employee taps **Check In**; the timestamp is recorded.
2. Default mode is **Onsite** and the day is marked **Present** immediately. No approval is needed.
3. If the employee has an active, approved Remote Work permission covering today, they may select **Remote** and are marked Present (Remote).
4. If they select Remote **without** an approved permission, the check-in is flagged as unauthorized: it does not count as Present, the employee is marked Absent pending review, and it is queued for HR.
5. If the employee has opted in to location capture, the location is recorded as reference information visible to HR and managers.
6. Also supported: break time, late arrival, early leave, overtime, a per-company shift schedule, monthly calendar and attendance reports.

6.2 Remote Work Request (standing permission, two-step approval)

Remote work is granted as a standing permission, not approved on every check-in.

1. The employee submits a request: reason plus either a date range (optionally specific weekdays) or "ongoing until revoked".
2. **Step 1:** the requester's direct manager reviews. Employee → Team Lead; Team Lead → Department Manager; Department Manager → HR or Company Admin. If rejected, the request ends and the requester is notified.
3. **Step 2:** HR gives final approval. If rejected, the request ends and the requester is notified.
4. After both approvals the employee can select Remote on any covered date.
5. HR or Company Admin can revoke an active permission at any time.

6.3 Absence marking

An employee of any role is marked **Absent** for a day if, by end of day: no check-in was recorded, **and** no approved leave covers the day, **and** no valid approved Remote Work permission was used. Weekends and company holidays are excluded. An unauthorized remote check-in does not count as Present.

6.4 What HR sees

- **Remote Work Approval Queue:** requests that have cleared the manager and await HR's final sign-off.
- **Exceptions Queue:** unauthorized remote check-ins and other flagged anomalies, to review and resolve.
- Routine onsite check-ins are automatic and need no HR action.

6.5 Work timer and break notifications (supervisor's top recommendation)

- After checking in, the employee starts a **work timer**; it runs until they stop it or check out.
- When the employee goes on a **break**, the timer pauses and a real-time notification (in-app, with email where enabled) goes to their **Team Lead, their manager (Department Manager) and the Company Admin / CEO**.
- Each company sets the allowed break time in its shift schedule. **Once the break time ends, overtime counting starts.** The exact rule is confirmed in Section 22.
- Late arrival, early leave, break minutes and overtime are all recorded on the day's attendance record and appear in reports.
- The timer is a **Premium plan** feature (Section 10.1).

6.6 Login IP and location tracking (optional, if time allows)

- On every login the system captures the **IP address and an approximate location (latitude/longitude derived from the IP)** and shows it on the user's profile as a plain sentence: "You logged in from [place] at [time]".
- HR maintains an **IP whitelist for remote and hybrid employees**. If a company turns on an office-network restriction, whitelisted employees are exempt; without a whitelist, the restriction would wrongly apply to people working from home.

- By default this is informational. If the office restriction is enforced, a check-in from a non-whitelisted IP goes to the HR exceptions queue instead of being blocked, which keeps it consistent with the privacy decision at the top of this section. To be confirmed in Section 22.
- The location is IP-derived and approximate, not GPS. Employees must be told it is collected.
- Research task: choose a Node/NestJS IP-geolocation library or service.

---

7. Leave Management

7.1 Probation

- Applies **only to users with the Employee role**. HR Manager, Department Manager and Team Lead are exempt: leave is allocated and available from their first day.
- Default length is **3 months from the hire date**, configurable per company on the Company Profile.
- During probation no leave is allocated and none can be requested. Leave balances (Earned, Casual, Sick) are allocated automatically when probation ends.
- The system must show a probationary employee their probation end date and why leave is unavailable, rather than silently blocking the option. The message never appears for HR, managers or Team Leads.
- The employee is notified shortly before probation ends and again when leave becomes available.

7.2 Leave types

Leave type	Requirement to apply	Approval flow
Casual	Written reason	Team Lead, then HR (final)
Sick	Prescription uploaded	Team Lead, then HR (final)
Annual	Written reason	Team Lead, then HR (final)

Leave types and yearly allocations are configurable per company. The Company Admin or HR has a **setting toggle** that decides whether the reason (Casual, Annual) and the prescription (Sick) are mandatory; the default is mandatory. CEO-level leave is simply

recorded by HR or the CEO, with no deeper hierarchy.

HR leave list: HR sees a list of leave requests. Clicking one opens a modal or page showing the reason, with a button to download the prescription. Every decision sends an in-app notification and an email.

7.3 Flow (Team Lead, then HR final approval)

1. The system checks probation (Employee role only). If the user is still on probation, the application is unavailable.
2. The requester selects type and date range and provides the reason or prescription (unless the toggle makes it optional).
3. The request goes to the **Team Lead first, then to HR for final approval**:
   - Employee → Team Lead → HR (final)
   - Team Lead → their manager (Department Manager) → HR (final)
   - Department Manager → HR (Company Admin as fallback)
   - HR Manager → Company Admin
   - CEO-level leave is not routed; HR or the CEO records it.
4. Each approver approves or rejects with a comment. Every step sends an in-app notification and an email; HR is notified, with an email, when a request reaches final approval.
5. **On final approval:** balance is decremented, the dates are marked On Leave for attendance, and the requester is notified.
6. **On rejection at any step:** no balance change; the requester is notified with the reason.
7. **On cancellation before the leave starts:** balance is restored.

Change from v2.0: the earlier manager-only phase is superseded by the supervisor's flow (Team Lead, then HR final approval). Because routing is template-driven (Section 8), this is a template change, not a rewrite. Whether a Team Lead's leave also needs HR's final sign-off is confirmed in Section 22.

---

8. Configurable Approval Routing (system requirement)

Approval chains are not hardcoded per feature. One shared mechanism serves Leave, Remote Work and Resource Requests.

- Each request type has a **chain template**: an ordered list of steps.

- A step resolves its approver at request time from the requester's **actual reporting line** (direct manager, department manager, or any user holding a configured role), never from fixed user IDs.
- Steps can be **auto-skipped** for certain requester roles (for example, a Department Manager has no department manager above them).
- Templates are **configurable per company** through settings, with no code change required, and an HR-level permission controls who may edit them.
- Every step records approver, timestamp, decision and comment, giving a full audit trail.
- Adding another platform or company role later must not require restructuring the permission model.

---

9. Resource Request Module

Inspired by office-automation systems: employees request company resources (laptop, chair, software access, stationery) through an upward-escalating chain.

1. The employee submits a request (category, item, quantity, reason) to their direct manager.
2. The **Team Lead** approves and forwards, or rejects (request ends, employee notified).
3. The **Department Manager** approves and forwards to the fulfilling department, or rejects.
4. The **fulfilling department** (for example IT for a laptop, Admin for stationery) fulfils or rejects.
5. Status is visible end to end: Pending → Manager Approved → Forwarded → Fulfilled / Rejected.

Categories are configured once per company, with the fulfilling department set per category. Each step is audit-logged. Anyone belonging to the fulfilling department can act on its queue; HR has company-wide oversight.

---

10. Subscription & Billing

10.1 Plans

Feature	Basic	Premium
Core HR (employees, attendance, leave, payroll)	Included	Included
Work timer and break notifications	Off	On
File upload	Off	On
AI Assistant	Off	On

Basic switches off the work timer, file upload and AI assistant; Premium turns all three on. Two points need confirmation (Section 22): Sick leave needs a prescription upload, so leave attachments are assumed to stay available on Basic; and the earlier Free and Professional tiers (with limited and unlimited AI) are superseded by this two-tier model.

10.2 Who sees what

Capability	Super Admin	Company Admin
View subscriptions	All companies	Own company only
View plan, start and expiry date	Per company	Own company
Expiry warning notification	Yes (all companies)	Yes (own company)
Add a company	Yes	No
Upgrade / downgrade plan	No (support only)	Yes
Billing history and invoices	All	Own

Operation Manager has no billing access.

10.3 Payment collection and retries

- Subscribing and updating a card use Stripe's **ready-made payment widget**, on both the frontend and the backend.
- A **scheduled job (cron)** tries to collect payment on the subscription **end date**. If it fails, it **retries on the next three days** (day 1, day 2, day 3).

- Every failure is **recorded with its error** (for example, insufficient funds) and the **subscriber is emailed**; the Company Admin also gets an in-app notice.
- If all retries fail, the missed payment counts toward the non-payment lockout in 10.4.

10.4 Non-payment enforcement

If a company fails to pay or renew for **2 consecutive months**, the platform blocks login for **every user of that company** until payment resumes.

1. An unpaid or lapsed subscription triggers warnings well before the lock (at the first missed payment and ahead of expiry), using the same notification pipeline as expiry warnings.
2. At the 2-month threshold the company status becomes **Suspended (Non-Payment)**.
3. Every login and every already-issued session of that company is rejected with a clear message, such as "Your company's subscription has lapsed — contact your administrator".
4. Super Admin and Operation Manager (read-only) can see the suspended status and payment history. Platform users are never locked out.
5. When payment is received, the company reverts to Active and logins are restored immediately, automatically.

---

11. Employee Module

Employee CRUD; documents (upload with file validation); profile; emergency contacts; education; experience; skills; promotion history; resignation (employee submits, HR manages); termination (Company Admin); employee timeline of events; bank details. Each employee has a designation, department and reporting manager, and the reporting line drives approval routing.

Employee status badges. When an employee is suspended or placed on probation, the employee is notified and an icon or badge appears on their profile and in employee lists. Statuses are Active, On probation, Suspended, On leave, Resigned and Terminated. The supervisor's reasoning: it keeps the scope contained while making the system more valuable.

12. Payroll

Salary structure; allowances, bonuses and deductions; tax; salary revision history; payroll runs; **payslip generator with PDF output**; bulk payslip generation; payroll history; bank details. HR manages payroll; Company Admin views and approves; employees see only their own payslips. Employees are notified when payroll is generated.

13. Bulk Upload

HR uploads an Excel file. The system validates the data, shows a preview with errors highlighted, imports the valid employees, generates payroll automatically, generates payslips, emails them, and provides a downloadable error report. Import runs as a background job so large files do not block the request.

---

14. Security, Authentication & Multi-tenancy

14.1 Authentication

JWT access tokens with refresh tokens in secure cookies; email verification; forgot and reset password; session management (list and revoke sessions); rate limiting; **account locking** after repeated failed logins; optional two-factor authentication (TOTP with backup codes); audit logs for sensitive actions.

14.2 Platform security

Helmet security headers; CSRF protection; rate limiting; XSS protection; SQL-injection prevention through the ORM; input validation on every endpoint; RBAC plus data scope on every query; encryption of secrets at rest; environment-variable validation at boot; file-type validation on uploads.

14.3 Login activity (Company Admin)

Company Admin can see each employee's role, last login time and last login **device and approximate location** (browser/OS label and coarse city or region derived from the connection). This is deliberately lighter than GPS, consistent with the privacy decision in Section 6.

14.4 Multi-tenancy

Every tenant-owned record carries a company identifier, and every query is scoped to the caller's company automatically at the data layer. Platform roles are the only tenant-agnostic users, and their access to company operational data is restricted as described in Section 5.1.

14.5 File storage

Uploaded files (employee documents, leave prescriptions) go to **Cloudinary (free tier) or AWS S3**. The file is stored there and **only its link (URL) is saved in the database**. Type and size validation apply to every upload. File upload is a Premium-plan feature (Section 10.1).

---

15. AI HR Assistant

Powered by Google Gemini, used as is: no model training is needed, because Gemini is already trained. The model must **not** answer directly; every request passes through prompt engineering:

- A system prompt defines the assistant's role and boundaries.
- **Context injection:** company policies, HR rules, the employee's own context (such as leave balance) and the user's role.
- **Topic guardrails:** answers HR questions only. Politely refuses politics, religion, adult content, abuse, hate speech, illegal activity, programming unrelated to HR, medical advice and financial advice. A pre-check classifier and prompt-injection detection run before the model is called.
- **Conversation history** is kept per user.
- Responses include **related page links** (for example, "Show payroll page" returns a link).
- Examples: leave balance, how to apply for leave, maternity leave policy, summarise HR policy, generate a leave application.
- **Plan gating:** AI is off on Basic and on for Premium. If a usage limit is configured, reaching it notifies the user and Company Admin.
- Access: Company Admin, HR, managers and newly onboarded users (onboarding help); access for other employees is pending confirmation (Section 22). Users only get data within their own scope. Super Admin configures platform-wide limits and does not chat as an HR user.

16. Notifications

Real-time (Socket.IO) and email, with per-user preferences.

Event	Recipient
Subscription expiring soon	Super Admin (all companies), Company Admin (own)
New company added	Super Admin
Unauthorized remote check-in flagged / resolved	HR / requester
Employee goes on a break (work timer)	Team Lead, manager, Company Admin / CEO
Leave submitted	Team Lead (employees), Department Manager (Team Leads), HR (Department Managers)
Leave awaiting final approval	HR (in-app and email)
Leave approved or rejected, at each step	Requester (in-app and email)
Probation ending soon / leave now available	Employee
Employee placed on probation or suspended	Employee and HR
Remote Work Request submitted	Requester's direct manager (step 1)
Remote Work approved by manager	HR (step 2 pending)
Remote Work approved or rejected (final)	Requester
Resource request submitted, forwarded, fulfilled, rejected	Requester and each approver
Payroll generated	Employee
Payment failed (with the error, such as insufficient funds) and retry scheduled	Subscriber by email, Company Admin in-app
Company locked / unlocked	Company Admin, Super Admin
AI usage limit reached (if a limit is configured)	Employee / Company Admin
Attendance reminder, system updates	Employees

17. Dashboards & Analytics

Dashboard	Contents
Super Admin / Operation Manager	Total companies, revenue, subscriptions, active users, AI usage, server status (Operation Manager read-only)
Company Admin	Employees, **present / absent / on-leave graph with trend**, leaves, payroll summary, departments, hiring, attrition
HR Manager	Company KPIs plus pending queues: remote-work final approvals, attendance exceptions
Department Manager / Team Lead	Department or team attendance, pending approvals
Employee	Own attendance, leave balance, next payslip, notifications, tasks

Analytics (Recharts): attendance, payroll, hiring, leave, department, AI usage, revenue and subscription analytics, each scoped to the viewer's role (platform, company, department, team, self).

---

18. Module Visibility Matrix

Legend: **Full** = create/edit/delete · **Manage** = full operations including approvals · **View** = read-only · **Dept / Team / Self** = scoped · **—** = hidden.

Module	Super Admin	Operation Manager	Company Admin	HR Manager	Dept Manager	Team Lead	Employee
Dashboard	Platform	Platform (view)	Company	Company + queues	Dept	Team	Self
Companies	Full	View	—	—	—	—	—
Employees	—	—	All (view, structure)	All (manage)	Dept	Team	Self profile
Departments	—	—	Full	Manage	View own	View own	—

Module	Super Admin	Operation Manager	Company Admin	HR Manager	Dept Manager	Team Lead	Employee
Designations	—	—	Full	Manage	View	View	—
Attendance	—	—	View company	Manage, remote final approval, exceptions	Own + dept view + remote step 1	Own + team view + remote step 1	Self
Work Timer (Premium)	—	—	Break alerts	Own + view	Own + dept break alerts	Own + team break alerts	Own
Leave	—	—	View; approves HR's leave; records CEO-level leave	Full list with reason and prescription; final approval	Apply + approve Team Leads'	Apply + first approval for team	Apply + view (after probation)
Payroll	—	—	View company	Manage all	Self + limited team view	Self	Self
Resource Requests	—	—	View	Oversight	Submit + step 2	Submit + step 1	Submit
AI Assistant (Premium)	Configure platform limits	—	Configure + use	Configure + use	Use	Use	Onboarding use (to confirm)
Analytics	Platform	Platform (view)	Company	Company HR	Dept	Team	Self
Billing	All companies	—	Own company	—	—	—	—
Settings	Platform config, plans	Own profile	Company settings, leave toggle	HR settings, IP whitelist	Profile	Profile	Profile + location consent

The work timer, file upload and AI Assistant require the Premium plan.

---

19. Non-Functional Requirements

- **Quality:** clean architecture, SOLID principles, reusable code, TypeScript strict mode, linting and pre-commit formatting.
- **Database:** ER diagram, Prisma models, indexes, constraints and normalisation; data dictionary generated from the schema.
- **APIs:** complete REST APIs with request and response examples, versioned, documented with OpenAPI/Swagger, with one consistent response envelope.
- **UI:** landing and pricing pages, responsive design, dark mode, loading skeletons, empty states, error pages. Optional polish (the supervisor said to add it only if wanted): a minimal look with light effects such as scroll and cursor animations and icon movement.
- **Testing:** unit, integration, API, security, performance testing and UAT, with written test cases.
- **Deployment:** go live by 10 November 2026, with the frontend on Vercel and the backend on Render (Vercel's request timeout is a problem for the API), managed PostgreSQL and Redis, Docker, CI/CD with GitHub Actions, SSL, monitoring and logging. The live link is shared with the supervisor, and an example environment file (.env.example) is committed to the repository.
- **Documentation:** SRS, SDD, architecture, ER, sequence, class, use-case, activity and deployment diagrams, data dictionary, API documentation, installation guide, user and admin manuals, presentation slides, viva questions, project report, code comments, README.

20. Decisions Finalized by the Company Owner and Supervisor (August to October 2026)

1. Leave approval is now **Team Lead, then HR final approval** (supervisor, October 2026). This replaces the earlier manager-only phase.
2. Remote work uses a two-step standing permission (manager, then HR); no GPS verification.
3. Leave allocation is gated by a 3-month probation (configurable) for the Employee role only.
4. Location capture is consent-based and informational only.
5. A 2-month non-payment period locks the whole company until payment resumes; Stripe payment is retried on the next three days after the end date.

6. The **work timer with break notifications** (Team Lead, manager, CEO/admin) and overtime after break time is the supervisor's top-recommended addition.
7. Login IP and location tracking, with an HR IP whitelist, is optional, if time allows.
8. Plans are **Basic** (timer, file upload and AI off) and **Premium** (all on).
9. Leave types are Casual, Sick and Annual; reason or prescription is mandatory, with a Company Admin / HR toggle.
10. Files go to Cloudinary or S3, and only the link is stored.
11. Gemini only, no training, HR topics only; access for Admin, HR, managers and new users.
12. Suspension and probation notify the employee and show a profile badge.
13. Deployment by **10 November 2026**: frontend on Vercel, backend on Render, live link to the supervisor, `.env.example` in Git.
14. UI polish is optional and minimal.

Explicitly out of scope (confirmed by the supervisor)

- Screenshot snapshots every 10 minutes: the supervisor called it "too advanced"; it brings bugs and permission issues and needs separate storage.
- A Covid-based concept: the timer is the better option.
- A deep CTO/CEO leave hierarchy: CEO-level leave is only recorded by HR or the CEO.
- Model training: Gemini is already trained.
- Face verification (earlier decision).

---

21. Implementation Status vs. This Specification

Result of the repository audit (static code read; the application and tests were not executed).

Area	Status
Operation Manager role, remote work flow, exception queue, consent-based location, approval engine, resource requests, billing lockout, login activity, 2FA, AI guardrails, plan gating, tenant isolation	Implemented

Area	Status
Leave chain: code seeds Department Manager → HR → Company Admin, so a Team Lead is never the first approver; the spec now requires Team Lead → HR (final) through the reporting line	**Fix required**
Probation: code uses a designation flag anchored to designation date; spec requires Employee role only, from hire date, plus an "ending soon" notice	**Fix required**
Super Admin data access: code gives full cross-company read with no logged support mode; spec forbids this	**Decision and fix required**
Company Admin inherits HR approval permissions; spec says view-only except top-of-chain cases	Align
Absence is derived at report time, not recorded by an end-of-day job	Add nightly job
Manager team-payroll view (limited) not implemented	Align
Lockout is triggered by 2 consecutive failed invoices rather than expiry plus 2-month grace	Document
SRS, user manual and data dictionary still describe GPS check-in; Operation Manager and Resource Requests are undocumented	Update docs

22. Remaining Open Items

1. **Google OAuth login:** required by the original brief but removed from the code. Confirm it is intentionally out of scope and update the brief and README, or restore it.
2. **Super Admin support mode:** confirm the policy (logged support mode, or documented trusted-operator access).
3. **Department Manager's own requests:** confirm whether HR or Company Admin is the default approver.
4. **Team Lead and Department Manager payroll visibility:** confirm the limited team view for managers and none for Team Leads.

5. **Resource Request module:** confirm it is in scope for submission (it is built).
6. **Location consent:** confirm it lives in Settings and can be withdrawn at any time (recommended: yes).
7. **Completion Guide:** the changelog refers to `SaaS_HRMS_FYP_Completion_Guide.pdf`, which was not supplied; merge any sprint or phase plan from it into Section 19.
8. **Plans:** confirm Basic and Premium replace Free, Basic and Professional, and that leave prescription uploads stay available on Basic even though file upload is off.
9. **Team Lead's own leave:** approved by their manager only, or by their manager and then HR?
10. **Overtime rule:** the list says overtime starts after break time ends. Does that mean time beyond the allowed break, or work after the shift ends?
11. **Break notifications:** sent on every break, or only when a break runs past the allowed time?
12. **IP whitelist:** should a non-whitelisted IP block check-in or only flag it for HR, and is IP-derived latitude/longitude acceptable given the privacy decision?
13. **AI access:** do regular employees keep access after onboarding, or only Admin, HR, managers and new users?
14. **Hosting:** Render needs managed Redis (BullMQ) and PostgreSQL plus a way to run the scheduled jobs; confirm the plan before 10 November.

This document should be updated as decisions are finalized and used as the basis for development, the FYP report and the viva defense.

---

23. Supervisor Additions: Delivery Plan to 10 November 2026

The live deadline is 10 November 2026, 16 days after 25 October 2026. The order below follows the supervisor's own priority. Repo status comes from a keyword search of the code, not a full read, so treat "not found" as "check before building".

#	Addition	Spec section	Priority	Repo status
1	Work timer and break notifications	6.5	Top recommended	Break start/end endpoints and a check-in card exist; notifications to Team Lead, manager and CEO, and the overtime-after-break rule, were not found
2	Login IP tracking and HR IP whitelist	6.6	If time allows	Last-login device, coarse location and IP on sessions exist; latitude/longitude on the profile and an IP whitelist were not found
3	Stripe widget, cron retries, failure email	10.3	Required	Stripe billing, webhooks and lockout exist; a scheduled retry job on the end date and a recorded failure error were not found (retries rely on Stripe's own)
4	Basic and Premium tiers	10.1	Required	Free, Basic and Professional plans with feature flags and an AI limit exist; timer and upload gating were not found
5	Leave: Casual, Sick, Annual; Team Lead then HR	7	Required	Per-type reason and document flags exist; the default chain is Department Manager, HR, Company Admin and must change; the HR leave modal with prescription download was not verified
6	File storage on Cloudinary or S3	14.5	Required	An S3 client with a local fallback exists; Cloudinary was not found

#	Addition	Spec section	Priority	Repo status
7	Gemini limited to HR topics	15	Required	Guardrails exist; role access must be narrowed per Section 22
8	Suspension and probation badges	11	Required	A Suspended status exists; probation is a designation flag; badges and notifications were not verified
9	Deployment on Vercel and Render	19	Deadline	Docker and Nginx files exist; no Render or Vercel config was found, and only the API example env file was found
10	UI polish	19	Optional	Not started